Reconocimiento pasivo del dominio vulnweb.com con Censys, Wayback Machine y WHOIS

Andrés Felipe Céspedes Rondón
Ciberseguridad 2026 G01 — Ciencias de la Computación e Inteligencia Artificial
Universidad Sergio Arboleda, Bogotá, Colombia
Docente: MSc. Iván Darío Méndez Aguilera — Octubre de 2026

***Resumen*—Este informe documenta un reconocimiento pasivo (OSINT) sobre *vulnweb.com*, el dominio con el que Acunetix/Invicti publica aplicaciones web vulnerables a propósito para probar escáneres. Se hicieron seis búsquedas en Censys sobre certificados, puertos, servicios, versiones de software, geolocalización y proveedor de red. Se recuperaron cuatro versiones históricas del sitio en Wayback Machine (2012, 2016, 2020 y 2026) y se ejecutaron cinco variantes del comando *whois*, además de un *whois* de la IP y consultas DNS. El dominio, registrado en 2010 con Gandi a nombre de Invicti Security Limited (Malta), se aloja en tres IP de Amazon Web Services en Oregón y Virginia. Sus servicios solo atienden HTTP en el puerto 80, sin TLS, con software sin soporte (IIS 8.5 y PHP 7.1.26) y una página *phpinfo()* expuesta. Todo se obtuvo sin enviar tráfico de ataque al objetivo.**

***Palabras clave*—OSINT, reconocimiento pasivo, Censys, Wayback Machine, WHOIS, DNS, vulnweb.com, huella digital.**

I. Introducción

El reconocimiento es la primera fase de una evaluación de seguridad. Su variante pasiva, el OSINT (*Open Source Intelligence*), reúne información de fuentes públicas (motores que escanean Internet, archivos históricos y registros de dominios) sin interactuar de forma intrusiva con el objetivo, así que el dueño del sistema difícilmente la detecta.

La consigna pedía un dominio que presentara posibles vulnerabilidades. Se eligió *vulnweb.com* porque cumple esa condición de forma legítima: sus subdominios (*testphp*, *testasp*, *testaspnet*, *testhtml5* y *rest*) son aplicaciones vulnerables a propósito que el fabricante publica para que se practique sobre ellas [8]. Así el análisis puede nombrar debilidades concretas sin afectar a una organización real.

Los objetivos fueron: (1) caracterizar la superficie expuesta con seis búsquedas en Censys; (2) comparar al menos cuatro versiones históricas del sitio en Wayback Machine; y (3) contrastar los datos de registro con cinco variantes de *whois*.

II. Metodología y herramientas

- **Censys Platform** [1], con una cuenta gratuita. Sin cuenta solo se permiten tres búsquedas al día, y el historial de servicios requiere un plan de pago.
- **Wayback Machine** [3]: se navegó por las capturas y se usó su API CDX [4] para listar una captura por año con su tamaño.
- **whois** 5.6.6 y **dig** en Kali Linux (contenedor `kalilinux/kali-rolling`), ejecutados el 29 de octubre de 2026.

Como punto de partida, el DNS resuelve *vulnweb.com*, *www*, *testphp* y *testhtml5* a **44.228.249.3**; *testasp* y *testaspnet* a **44.238.29.244**; y *rest* a **18.215.71.186**. Los cuatro servidores de nombres son de Amazon Route 53 y el correo (MX) lo maneja Google (Fig. 1). Esas tres IP sirvieron de pivote para Censys.

```
┌──(root㉿kali)-[~]
└─# dig +short vulnweb.com A; dig +short vulnweb.com NS; dig +short
testphp.vulnweb.com A; dig +short vulnweb.com MX
44.228.249.3
ns-1588.awsdns-06.co.uk.
ns-557.awsdns-05.net.
ns-136.awsdns-17.com.
ns-1450.awsdns-53.org.
44.228.249.3
10 alt1.aspmx.l.google.com.   ...
10 aspmx.l.google.com.
```

Fig. 1. Resolución DNS del dominio: registro A, servidores de nombres de AWS y correo de Google.

III. Reconocimiento con Censys

A. Búsqueda 1: certificados digitales

Consulta: `cert.names: "vulnweb.com"`

Censys devolvió 3 certificados y ninguno es un certificado real de *vulnweb.com* (Fig. 2). Los tres los emitió **MockServer** (*CN=www.mockserver.com, O=MockServer, L=London*), una herramienta de pruebas que actúa como proxy y genera certificados al vuelo. Censys los marca como *never-trusted* y *untrusted*. Dos tienen una vigencia absurda, del 14 de julio de 2022 al 20 de junio de 2123, y el tercero (9-oct-2024 a 14-oct-2025) ya expiró. Su lista de nombres (SAN) mezcla direcciones y dominios ajenos, como 1.1.1.1, 127.0.0.1 o api.ipify.org, junto a *testphp.vulnweb.com*. Lo más probable es que alguien haya visitado *testphp* a través de un MockServer y el certificado generado haya quedado indexado.

La conclusión práctica es que **no hay un certificado de una CA confiable para el dominio**, lo que coincide con que sus sitios solo responden por HTTP (búsqueda 2).

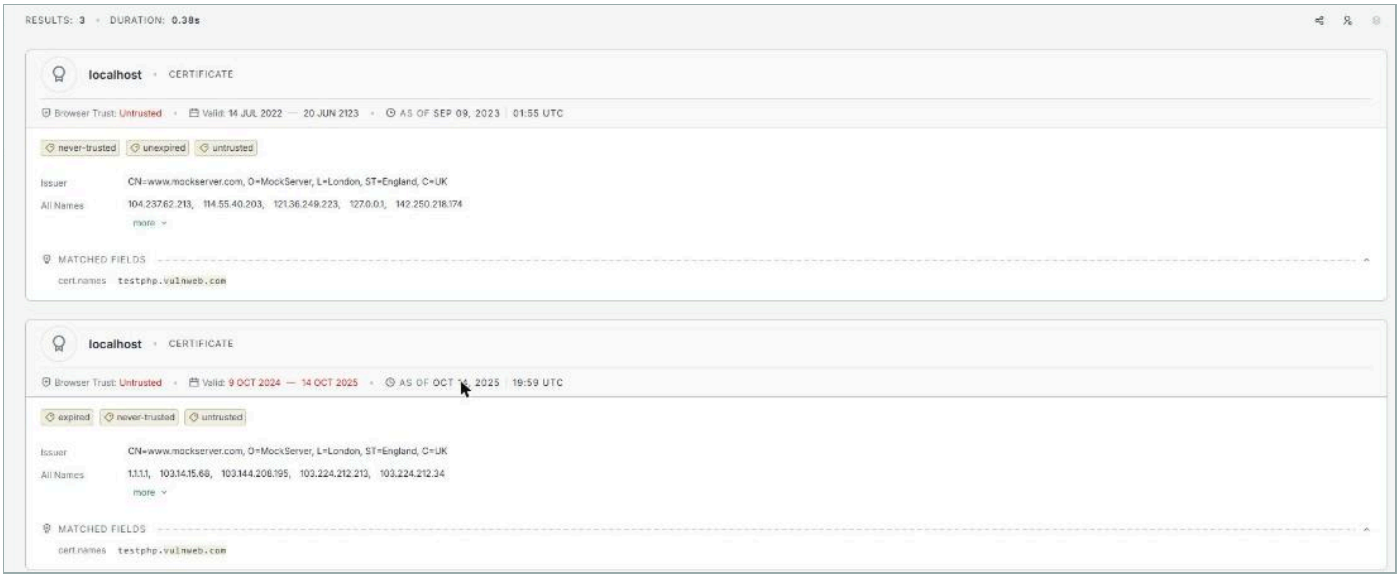


Fig. 2. Búsqueda 1 en Censys: certificados con *testphp.vulnweb.com* en sus nombres. El emisor es MockServer y el navegador no confía en ninguno (captura recortada; la completa está en *evidencias/censys/01_certificados.jpg*).

B. Búsqueda 2: puertos abiertos

Consulta: `host.dns.names: "vulnweb.com"`

La búsqueda devolvió 2 hosts (Fig. 3). Según los filtros de la izquierda, los dos tienen **un único puerto abierto, el 80/TCP con HTTP**; ninguno ofrece 443 (HTTPS). El tercer servidor, 44.228.249.3, que aloja la portada, *testphp* y *testhtml5*, no aparece en los resultados: al consultarlo directamente, Censys muestra 0 servicios y avisa que el host no tiene servicios visibles o está en su lista de bloqueo (Fig. 7). Ese vacío es en sí un dato, porque la fuente no cubre todo el objetivo y otra herramienta tendría que confirmarlo.

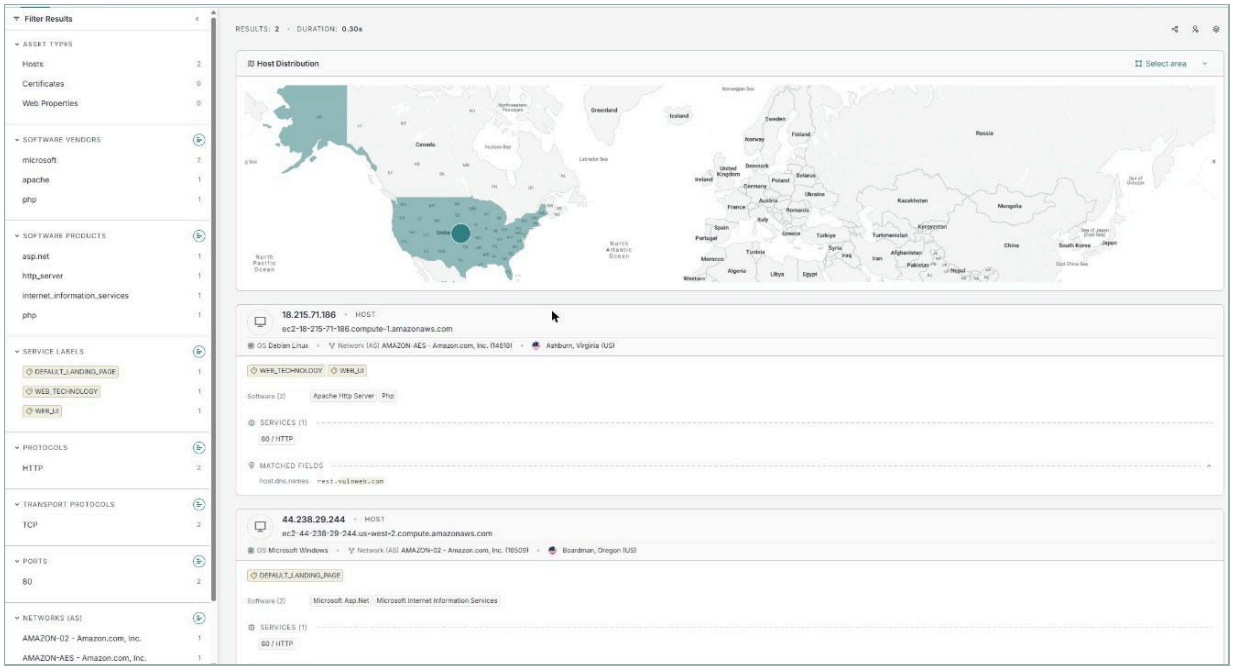


Fig. 3. Búsqueda 2 en Censys: 2 hosts asociados a *vulnweb.com*, ambos solo con el puerto 80 (filtro *Ports*). Los filtros también resumen fabricantes (Microsoft, Apache, PHP), redes (AMAZON-02 y AMAZON-AES) y ubicación (Estados Unidos).

C. Búsqueda 3: servicios expuestos

Al abrir cada host aparece el detalle del servicio HTTP (Fig. 4 y Fig. 5):

- **44.238.29.244** (*testasp*): Censys lo etiqueta *DEFAULT_LANDING_PAGE*. Pedido por IP responde la página por defecto de IIS (“IIS Windows Server”), así que el sitio de prueba solo aparece cuando se usa el nombre de host. El sistema operativo detectado es Microsoft Windows.
- **18.215.71.186** (*rest*): etiquetas *WEB_TECHNOLOGY* y *WEB_UI*, con el título “Invicti Vulnerable REST API”. Además de la raíz, Censys indexó la ruta **/info.php**, que

responde 200 con una página *phpinfo()* completa (Fig. 6). El sistema operativo detectado es Debian Linux.

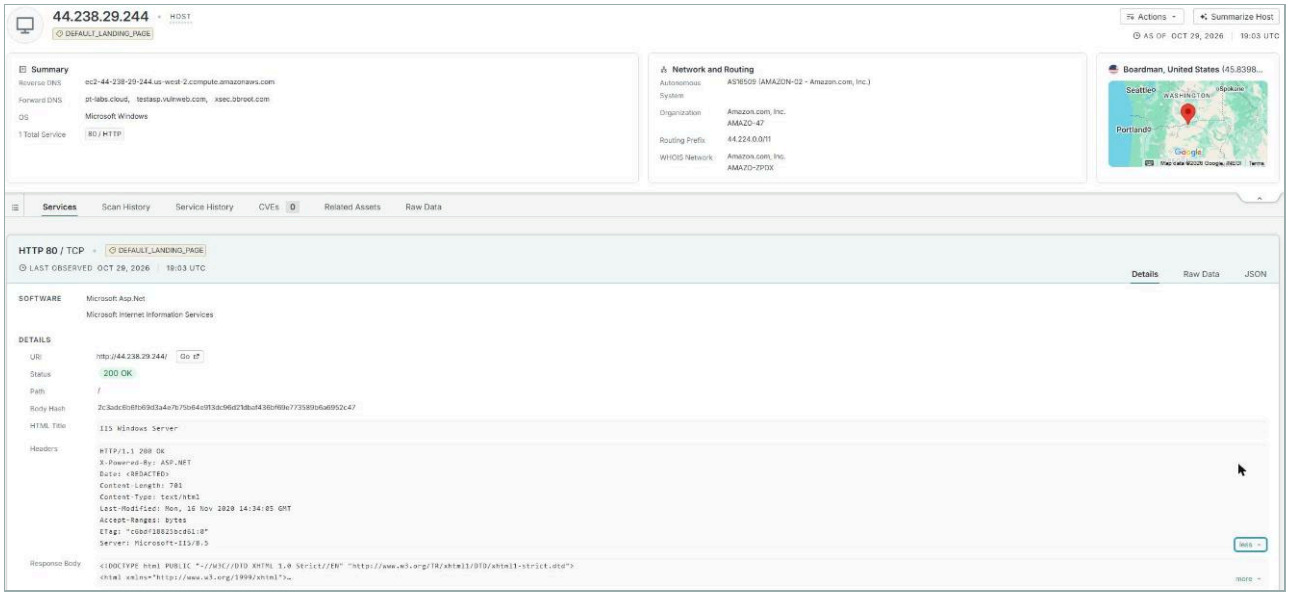


Fig. 4. Búsquedas 3 y 4: host 44.238.29.244 (*testasp.vulnweb.com*). Un solo servicio HTTP en el 80, software Microsoft IIS con ASP.NET, cabecera *Server: Microsoft-IIS/8.5* y página por defecto de IIS.

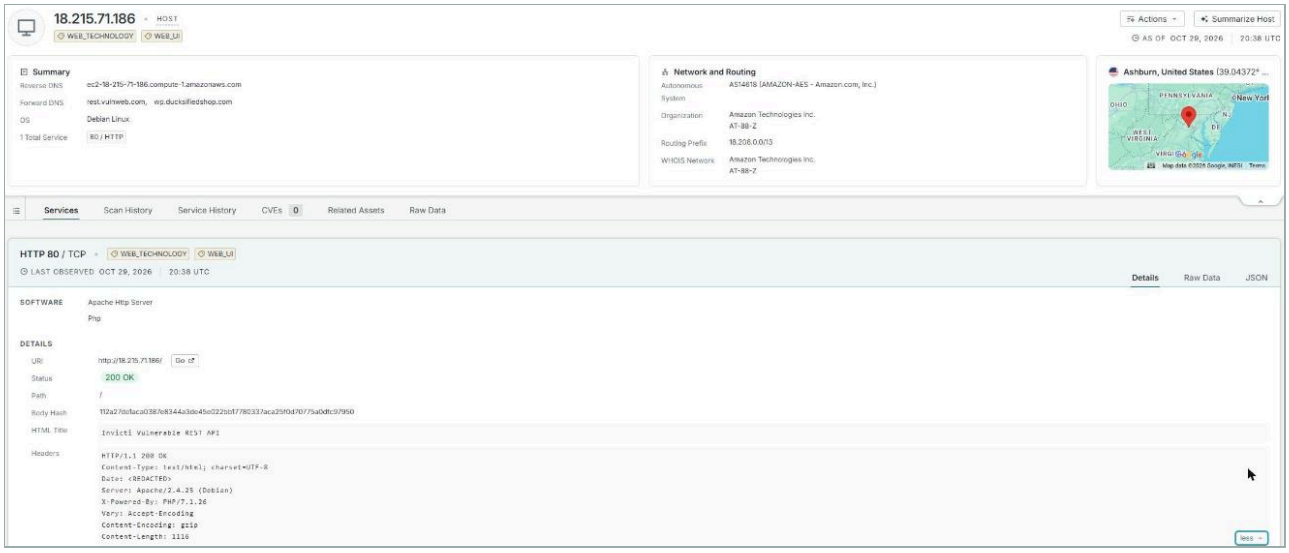


Fig. 5. Búsquedas 3 a 6: host 18.215.71.186 (*rest.vulnweb.com*). Las cabeceras revelan *Apache/2.4.25 (Debian)* y *X-Powered-By: PHP/7.1.26*. A la derecha, la red AS14618 (Amazon) y la ubicación en Ashburn, Virginia.

D. Búsqueda 4: versiones de software

Las cabeceras HTTP indexadas por Censys revelan versiones exactas (Fig. 4 y Fig. 5):

- **Microsoft-IIS/8.5** con **ASP.NET**: IIS 8.5 viene con Windows Server 2012 R2, que dejó de recibir soporte el 10 de octubre de 2023 [9]. La cabecera *Last-Modified* indica que la página por defecto no cambia desde noviembre de 2020.
- **Apache/2.4.25 (Debian)** y **PHP/7.1.26**: la rama PHP 7.1 dejó de recibir parches el 1 de diciembre de 2019 [10]. Apache 2.4.25 es de diciembre de 2016, y su rango de versiones aparece entre las afectadas por fallas como CVE-2017-9798 (*Optionsbleed*) y CVE-2019-0211 [11]. Debian aplica parches sin cambiar el número de versión, así que esto indica posibles vulnerabilidades pero no prueba que el servidor lo sea; la pestaña *CVEs* de Censys no reporta ninguna.
- El *phpinfo()* de */info.php* añade detalles internos: OpenSSL 1.0.2q, la ruta */var/www/public*, un nombre de host interno (*rest.testsparker.com*, de cuando Invicti se llamaba Netsparker) y un archivo *Shark.php* que se antepone a cada script, consistente con el sensor IAST que distribuye Invicti.



Fig. 6. Censys indexó *http://18.215.71.186/info.php* con el título *phpinfo()*: una página de diagnóstico expuesta públicamente.

E. Búsqueda 5: geolocalización de la IP

Censys ubica 44.228.249.3 y 44.238.29.244 en **Boardman, Oregón** (45,84° N, −119,70° O), y 18.215.71.186 en **Ashburn, Virginia** (39,04° N, −77,49° O). Más que ciudades donde esté la empresa, son las regiones de AWS *us-west-2* y *us-east-1*, como confirma el DNS inverso (*ec2-…us-west-2.compute.amazonaws.com* y *…compute-1.amazonaws.com*). El registrante, en cambio, está en Malta (sección V).

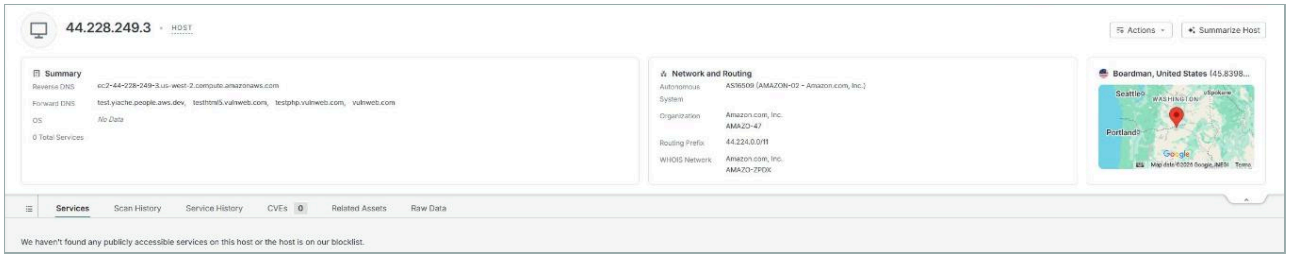


Fig. 7. Búsquedas 5 y 6: host 44.228.249.3. DNS directo hacia *vulnweb.com*, *testphp* y *testhtml5*; AS16509 (AMAZON-02), prefijo 44.224.0.0/11; ubicación en Boardman, Oregón. Censys no registra servicios para esta IP.

F. Búsqueda 6: proveedor de red

Las tres IP pertenecen a Amazon: 44.228.249.3 y 44.238.29.244 al sistema autónomo **AS16509 (AMAZON-02)**, prefijo 44.224.0.0/11, y 18.215.71.186 al **AS14618 (AMAZON-AES)**, prefijo 18.208.0.0/13. En el DNS directo de esas IP también aparecen dominios ajenos (*pt-labs.cloud*, *xsec.bbroot.com*, *wp.ducksifiedshop.com*, *test.yiache.people.aws.dev*). Son registros de terceros que apuntan a las mismas direcciones, algo frecuente con IP de nube que se reasignan, y muestran que una IP no basta para atribuir un servicio a un dueño.

IV. Análisis histórico con Wayback Machine

Wayback Machine guarda **511 capturas** de *http://vulnweb.com/*, del 21 de octubre de 2012 al 11 de marzo de 2026. Con la API CDX se listó una captura por año y se eligieron cuatro que marcan etapas distintas (Tabla I).

A. 21 de octubre de 2012: un WordPress sin configurar

La primera captura no tiene nada que ver con Acunetix: es una instalación de WordPress recién creada, con el tema por defecto, el lema “Just another WordPress site”, la entrada de ejemplo “Hello world!” del 24 de septiembre de 2012 y el enlace *Log in* visible (Fig. 8). Para un atacante de esa época, era un CMS sin actualizar con el panel de acceso a la vista.

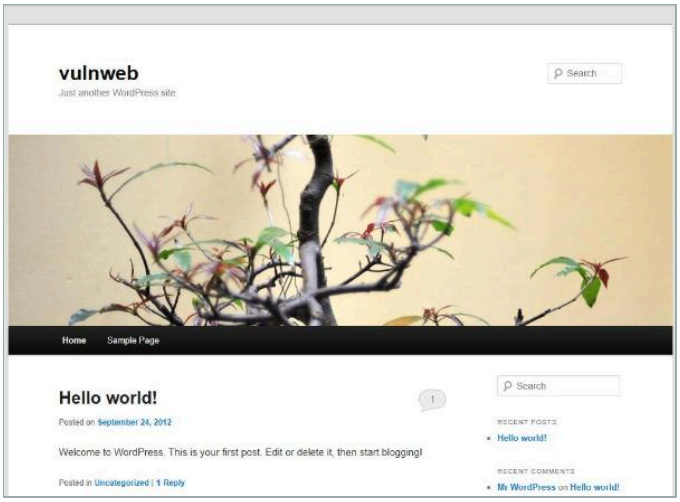


Fig. 8. *vulnweb.com* el 21-oct-2012: WordPress por defecto.

B. 2 de enero de 2016: portal de sitios de prueba

El dominio ya es el índice de “sitios web de prueba vulnerables” para el escáner de Acunetix. Es una página de HTML plano de menos de 1 KB, con una tabla de cuatro sitios y la **tecnología de cada uno**: SecurityTweets (*testhtml5*: nginx, Python, Flask, CouchDB), Acuart (*testphp*: Apache, PHP, MySQL), Acuforum (*testasp*: IIS, ASP, SQL Server) y Acublog (*testaspnet*: IIS, ASP.NET, SQL Server) (Fig. 9). El propio dueño publica la pila tecnológica, que normalmente es lo primero que un atacante intenta averiguar.



Fig. 9. *vulnweb.com* el 02-ene-2016: tabla de cuatro sitios con sus tecnologías.

C. 7 de enero de 2020: recursos y advertencia

Se agrega una columna *Resources*, con enlaces a la revisión del escáner correspondiente, y una franja gris con una advertencia: los sitios son intencionalmente vulnerables y sirven para aprender sobre inyección SQL, XSS o CSRF (Fig. 10). La página pasa de unos 900 a unos 1 600 bytes.

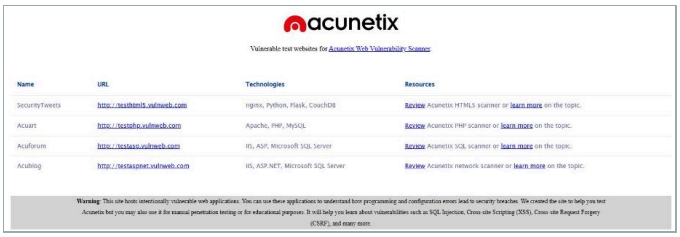


Fig. 10. *vulnweb.com* el 07-ene-2020: columna de recursos y advertencia.

D. 16 de enero de 2026: la API REST

La estructura se mantiene, pero aparece una quinta fila, **REST API** (*rest.vulnweb.com*: Apache, PHP, MySQL), que es justamente el host 18.215.71.186 de Censys (Fig. 11). La superficie de ataque del dominio creció de cuatro sitios a cinco, ahora también con una API.

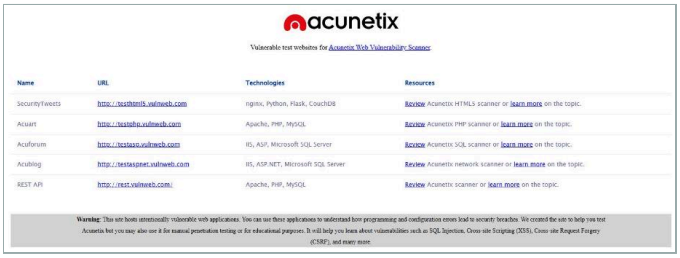


Fig. 11. *vulnweb.com* el 16-ene-2026: se suma *rest.vulnweb.com*.

TABLA I
EVOLUCIÓN DE VULNWEB.COM EN WAYBACK MACHINE

Fecha	Tamaño	Estructura y contenido
21-oct-2012	2 498 B	WordPress por defecto, sin relación con Acunetix; login visible.
02-ene-2016	897 B	Índice en HTML plano de 4 sitios de prueba con sus tecnologías.
07-ene-2020	1 599 B	Columna de recursos y advertencia de sitios vulnerables.
16-ene-2026	1 817 B	Quinto sitio: API REST (Apache, PHP, MySQL).

En síntesis, el dominio pasó de un blog genérico a un catálogo de objetivos de práctica, y desde 2016 mantiene el mismo diseño mínimo. El historial también sirve para atribuir: el WordPress de 2012 muestra que el dominio tuvo otro uso antes del actual, y la tabla de tecnologías permite saber qué esperar de cada subdominio sin enviarle ni una petición.

V. CONSULTAS WHOIS

Se ejecutaron cinco variantes de *whois* (protocolo del RFC 3912 [5], puerto 43/TCP), siguiendo los ejemplos del enunciado [6].

A. Variante 1: consulta estándar

`whois vulnweb.com` (137 líneas)

Para un *.com*, el cliente consulta primero al registro (Verisign) y luego sigue la referencia al servidor del registrador, Gandi, de modo que la salida trae los dos registros. Del registro se obtiene la información técnica y del registrador los datos del titular: **Invicti Security Limited**, país **MT** (Malta). El resto de los datos personales aparece como *REDACTED FOR PRIVACY* y el correo es un alias de Gandi (Fig. 12).

```
┌──(root㉿kali)-[~]
└─# whois vulnweb.com
   Domain Name: VULNWEB.COM
   Registrar: Gandi SAS            Registrar IANA ID: 81
   Updated Date: 2026-06-01T05:28:12Z
   Creation Date: 2010-06-14T07:50:29Z
   Registry Expiry Date: 2027-06-14T07:50:29Z
   Domain Status: clientTransferProhibited
   Name Server: NS-136.AWSDNS-17.COM   NS-1450.AWSDNS-53.ORG
   Name Server: NS-1588.AWSDNS-06.CO.UK  NS-557.AWSDNS-05.NET
   DNSSEC: unsigned
   ... (registrador: whois.gandi.net) ...
Registrant Name: REDACTED FOR PRIVACY
Registrant Organization: Invicti Security Limited
Registrant Country: MT
Registrant Email: e7c92ba2...@contact.gandi.net
```

Fig. 12. Variante 1, salida resumida (algunos campos se agruparon en una misma línea para ahorrar espacio).

B. Variante 2: sin avisos legales (-H)

`whois -H vulnweb.com` (107 líneas)

Devuelve los mismos datos pero omite el bloque *TERMS OF USE* de Verisign, 30 líneas menos. Es la opción práctica para guardar o procesar la salida.

C. Variante 3: servidor del registro (-h)

`whois -h whois.verisign-grs.com vulnweb.com` (57 líneas)

Al fijar el servidor, el cliente ya no sigue la referencia al registrador. La respuesta es el registro "delgado" de Verisign: fechas, estado, servidores DNS y DNSSEC, pero **ningún dato del titular** (Fig. 13).

```
┌──(root㉿kali)-[~]
└─# whois -h whois.verisign-grs.com vulnweb.com
   Domain Name: VULNWEB.COM
   Registry Domain ID: 1602006391_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.gandi.net
   Creation Date: 2010-06-14T07:50:29Z
   Registrar: Gandi SAS
   Domain Status: clientTransferProhibited
   DNSSEC: unsigned
   (sin campos Registrant / Admin / Tech)
```

Fig. 13. Variante 3: solo el registro de Verisign (resumida).

D. Variante 4: puerto explícito (-p 43)

`whois -p 43 vulnweb.com` (137 líneas)

La salida es idéntica, línea por línea, a la de la variante 1, porque 43 ya es el puerto por defecto del protocolo. La opción sirve cuando un servidor WHOIS atiende en otro puerto.

E. Variante 5: modo detallado (--verbose)

`whois --verbose vulnweb.com` (141 líneas)

Agrega las líneas que muestran la cadena de consultas: primero *Using server whois.verisign-grs.com* y, tras el registro, *Using server whois.gandi.net* con la cadena enviada (Fig. 14). Así se ve de dónde sale cada dato.

```
┌──(root㉿kali)-[~]
└─# whois --verbose vulnweb.com
Using server whois.verisign-grs.com.
   Domain Name: VULNWEB.COM
   ...
Using server whois.gandi.net.
Query string: "vulnweb.com"
Domain Name: vulnweb.com
Registrar WHOIS Server: whois.gandi.net
```

Fig. 14. Variante 5: el modo detallado revela la referencia de Verisign a Gandi.

F. Complemento: WHOIS de la IP

El *whois* de 44.228.249.3 responde ARIN. La IP está en el bloque 44.192.0.0/10 (AMAZO-4), del que se subasignó 44.224.0.0/11 (AMAZO-ZPDX), ambos de **Amazon.com, Inc.** (Seattle) y con un comentario que remite a EC2. Esto coincide con el sistema autónomo que reportó Censys.

Tabla II
Datos de registro de vulnweb.com

Campo	Valor e implicación
Creación / expiración	14-jun-2010 / 14-jun-2027: dominio con 16 años de antigüedad y vigente.
Última actualización	01-jun-2026 (registro) y 14-oct-2026 (registrador).
Registrador	Gandi SAS (IANA 81), Francia.
Titular	Invicti Security Limited, Malta; el resto está oculto por privacidad.
Estado	*clientTransferProhibited*: bloqueo contra transferencias no autorizadas [7].
DNS	4 servidores de AWS Route 53 en cuatro TLD distintos (redundancia).
DNSSEC	**unsigned**: las respuestas DNS no están firmadas.
Hosting	Amazon EC2 (AS16509 y AS14618); correo en Google.

Un detalle: el registrador anota la creación a las 05:50:29 y el registro a las 07:50:29 del mismo día. Es una diferencia de dos horas, seguramente de zona horaria, que muestra por qué conviene contrastar fuentes antes de citar una fecha exacta.

VI. Posibles vulnerabilidades identificadas

Cruzando las tres fuentes, y aclarando que en este dominio son debilidades intencionales, se identifican:

- **Tráfico sin cifrar:** todos los servicios atienden solo HTTP en el puerto 80 y no hay un certificado confiable. Las credenciales y cookies de los sitios viajan en claro.
- **Software sin soporte:** IIS 8.5 sobre Windows Server 2012 R2 y PHP 7.1.26 ya no reciben parches; Apache 2.4.25 pertenece a un rango afectado por CVE públicos.
- **Fuga de información:** */info.php* expone la configuración de PHP; las cabeceras *Server* y *X-Powered-By* anuncian versiones; y la portada lista la tecnología de cada sitio.
- **Configuración por defecto:** la página de bienvenida de IIS responde en la IP de *testasp*.
- **DNS sin DNSSEC:** un atacante en la ruta podría intentar envenenar la caché del resolver de una víctima y suplantar los nombres del dominio.

En un dominio de producción, cada punto sería un hallazgo para el informe: activar HTTPS con HSTS, actualizar o migrar los servidores, eliminar *phpinfo()*, ocultar las cabeceras de versión, quitar las páginas por defecto y firmar la zona con DNSSEC.

VII. Conclusiones

- **Las fuentes se complementan.** WHOIS dice quién es el titular y dónde se registra el dominio, Censys qué está expuesto y con qué versión, y Wayback cómo llegó el sitio a su estado actual. Las tres coinciden en la infraestructura: DNS de Route 53, IP de AWS y bloques de Amazon en ARIN.
- **Ninguna fuente es completa.** Censys no tiene servicios indexados para la IP principal (44.228.249.3) y limita el

historial a cuentas de pago, y WHOIS oculta los datos personales. Para cubrir esos vacíos hay que contrastar.

- **El historial también es inteligencia.** La captura de 2012 revela un uso anterior del dominio, y la tabla de tecnologías de 2016 en adelante entrega la huella técnica sin tocar un solo servidor.
- **Se pueden identificar posibles vulnerabilidades sin escanear:** versiones sin soporte, un *phpinfo()* expuesto, ausencia de TLS y DNSSEC. El escaneo activo, con autorización, solo tendría que confirmarlas.

Referencias

1. Censys, “Censys Platform.” [En línea]. Disponible: https://platform.censys.io
2. Censys, “Censys Query Language (CenQL).” [En línea]. Disponible: https://docs.censys.com/
3. Internet Archive, “Wayback Machine.” [En línea]. Disponible: https://web.archive.org
4. Internet Archive, “Wayback CDX Server API,” GitHub. [En línea]. Disponible: https://github.com/internetarchive/wayback/tree/master/wayback-cdx-server
5. L. Daigle, “WHOIS protocol specification,” RFC 3912, IETF, sep. 2004.
6. GeeksforGeeks, “How to use the whois command on Ubuntu Linux.” [En línea]. Disponible: https://www.geeksforgeeks.org/linux-unix/how-to-use-the-whois-command-on-ubuntu-linux/
7. ICANN, “EPP status codes: what do they mean, and why should I know?” [En línea]. Disponible: https://icann.org/epp
8. Acunetix, “Vulnerable test websites for Acunetix Web Vulnerability Scanner.” [En línea]. Disponible: http://vulnweb.com/
9. Microsoft, “Windows Server 2012 R2 – Microsoft Lifecycle.” [En línea]. Disponible: https://learn.microsoft.com/lifecycle/products/windows-server-2012-r2
10. The PHP Group, “Unsupported branches.” [En línea]. Disponible: https://www.php.net/eol.php
11. Apache Software Foundation, “Apache HTTP Server 2.4 vulnerabilities.” [En línea]. Disponible: https://httpd.apache.org/security/vulnerabilities_24.html
12. ARIN, “Search ARIN WHOIS/RDAP.” [En línea]. Disponible: https://search.arin.net